Laboratorio 09: Cloud Storage con Amazon S3

Informe de los ejercicios 1 al 4 · Junior Cueva Fabian · 14 de octubre de 2026

Alcance

Se creó un bucket privado, se probó el acceso de mínimo privilegio, se usó el versionado para recuperar un objeto y se desarrolló una galería local con URL prefirmadas. Las capturas de las primeras tres partes proceden del documento de laboratorio completado. El código y las evidencias se encuentran en el repositorio indicado al final.

Ejercicio 1: fundamentos de S3

1. ¿Por qué el nombre del bucket debe ser único a nivel global?

Porque el nombre participa en un espacio de direcciones compartido por las cuentas AWS de la partición. Dos cuentas no pueden crear el mismo nombre.

2. ¿Qué diferencia hay entre endpoint regional y global?

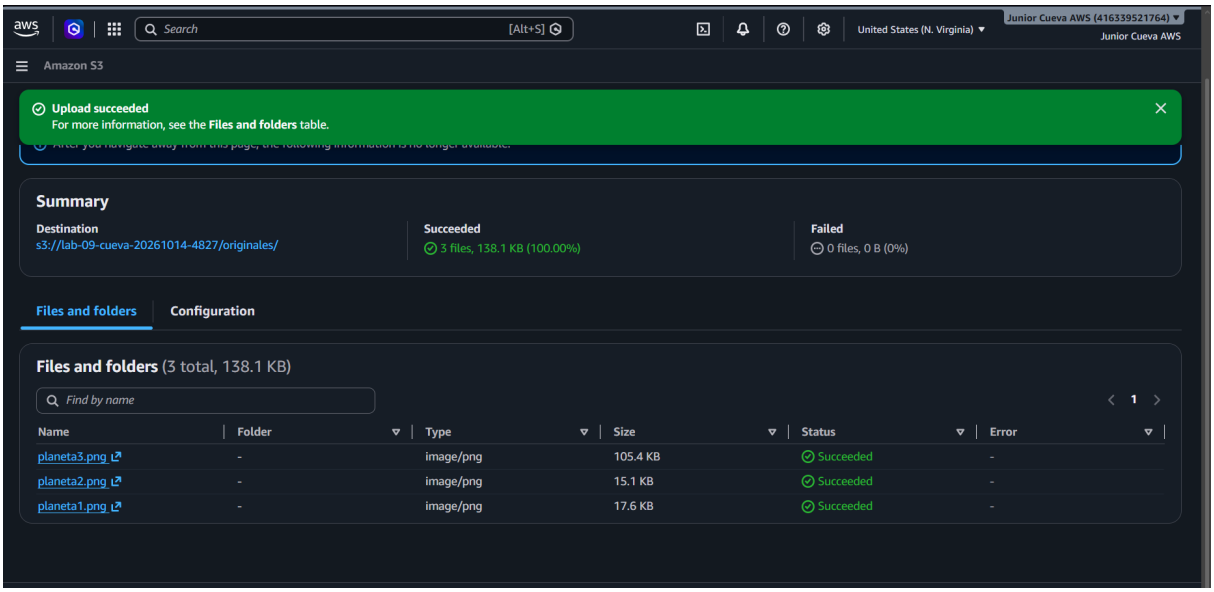
El endpoint regional dirige la solicitud a la región del bucket; el global es una dirección general que puede redirigirla a esa región.

3. ¿Qué ocurre al abrir la URL pública de un objeto?

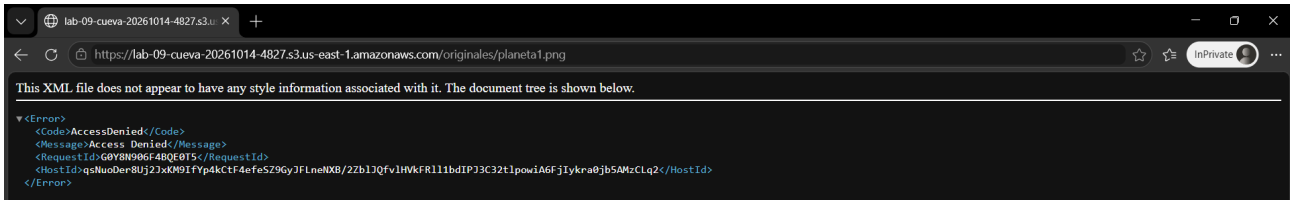
Aparece AccessDenied porque el acceso público está bloqueado. Conocer la URL del objeto no concede permiso de lectura.

Reflexión de seguridad

El bucket permanece privado y se usaron imágenes de prueba. Las credenciales locales de AWS no se publican ni se guardan en este repositorio.



E1 · Tres imágenes cargadas en originales/.



E1 · La URL directa del objeto devuelve AccessDenied.

Ejercicio 2: IAM y cifrado

1. ¿Qué diferencia hay entre política IAM y política de bucket?

La política IAM autoriza a una identidad; la política de bucket controla el recurso. Una denegación explícita prevalece sobre cualquier permiso.

2. ¿Qué diferencias hay entre SSE-S3, SSE-KMS y SSE-C?

SSE-S3 usa claves gestionadas por S3 y simplifica la práctica. SSE-KMS permite mayor control y auditoría, con permisos y costos adicionales. SSE-C exige que el cliente entregue y gestione su clave.

3. ¿Qué riesgo mitiga aws:SecureTransport?

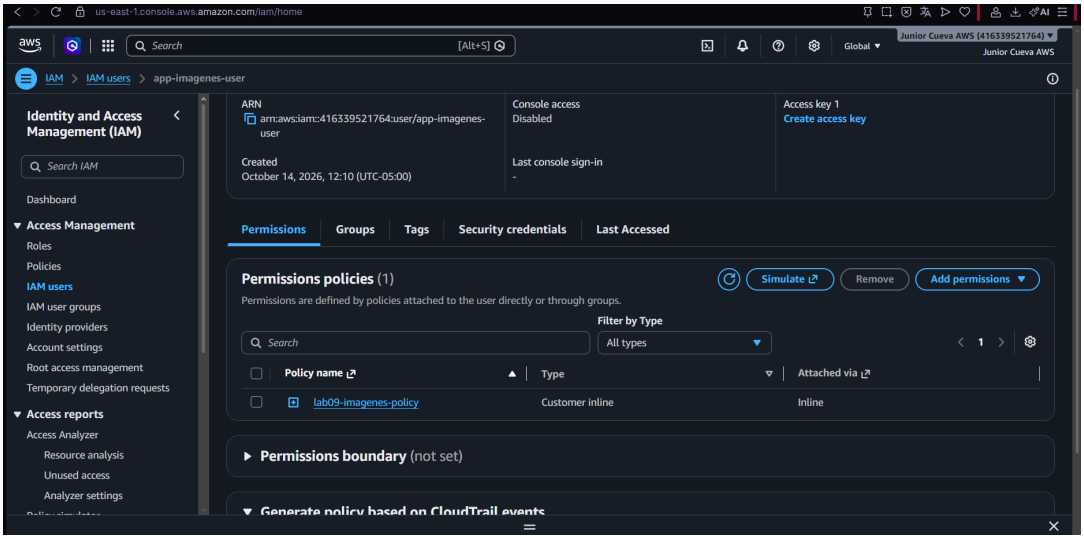
Impide solicitudes HTTP sin TLS y exige HTTPS para comunicarse con el bucket.

4. ¿Qué hacer si una Access Key se filtra en GitHub?

Desactivarla de inmediato, crear y configurar otra, eliminar la anterior y revisar CloudTrail y el uso de la cuenta. Borrar el archivo del repositorio no revoca la clave.

Reflexión de seguridad

El usuario app-imagenes-user tiene permisos limitados para operar objetos. La prueba de eliminar el bucket respondió AccessDenied. El objeto de prueba cifrado devolvió AES256, correspondiente a SSE-S3.



E2 · Política de permisos asociada al usuario IAM.

```
PS C:\Users\LENOVO> aws s3api delete-bucket --bucket lab-09-cueva-20261014-4827 --profile app-user

aws: [ERROR]: An error occurred (AccessDenied) when calling the DeleteBucket operation: User: arn:aws:iam::416339521764:
user/app-imagenes-user is not authorized to perform: s3:DeleteBucket on resource: "arn:aws:s3:::lab-09-cueva-20261014-48
27" because no identity-based policy allows the s3:DeleteBucket action
PS C:\Users\LENOVO>
```

E2 · El usuario no puede ejecutar DeleteBucket.

Ejercicio 3: versiones y ciclo de vida

1. ¿Se puede desactivar el versionado?

Una vez activado, puede suspenderse, pero las versiones existentes permanecen. Al borrar un objeto se crea normalmente un marcador de borrado; al quitarlo vuelve a verse la versión anterior.

2. ¿Cuánto cuesta almacenar 100 GB durante un año si el 80 % deja de consultarse tras el primer mes?

Cálculo ilustrativo de solo almacenamiento en us-east-1: Standard USD 0,023/GB-mes, Standard-IA USD 0,0125 y Glacier Instant USD 0,004. Mantener 100 GB en Standard cuesta USD 2,30 al mes, o USD 27,60 al año. Si 80 GB pasan a Standard-IA después de 30 días y a Glacier Instant después de 90 días, mientras 20 GB siguen en Standard, el primer año suma aproximadamente USD 12,24 (promedio USD 1,02 al mes).

Cálculo: mes 1, 100 × 0,023 = 2,30; meses 2-3, 20 × 0,023 × 2 + 80 × 0,0125 × 2 = 2,92; meses 4-12, 20 × 0,023 × 9 + 80 × 0,004 × 9 = 7,02. Total 12,24. No incluye solicitudes, transición, recuperación, mínimos de tamaño o permanencia, versiones extra ni impuestos. Mover solo el 80 % requiere un prefijo o filtro específico; una regla sobre todo originales/ movería todo ese prefijo.

3. ¿Qué añade MFA Delete?

Exige un segundo factor para borrar permanentemente versiones o cambiar el estado del versionado. Conviene para datos cuya pérdida sería grave.

Clases de almacenamiento investigadas

Clase	Uso recomendado	Recuperación
S3 Standard	Acceso frecuente	Milisegundos
S3 Standard-IA	Acceso infrecuente	Milisegundos
S3 One Zone-IA	Datos no críticos en una AZ	Milisegundos
Glacier Instant	Archivo con lectura ocasional	Milisegundos
Glacier Flexible	Archivo con espera aceptable	Minutos a horas
Glacier Deep Archive	Archivo de largo plazo	Horas
Intelligent-Tiering	Acceso variable o desconocido	Milisegundos en nivel frecuente

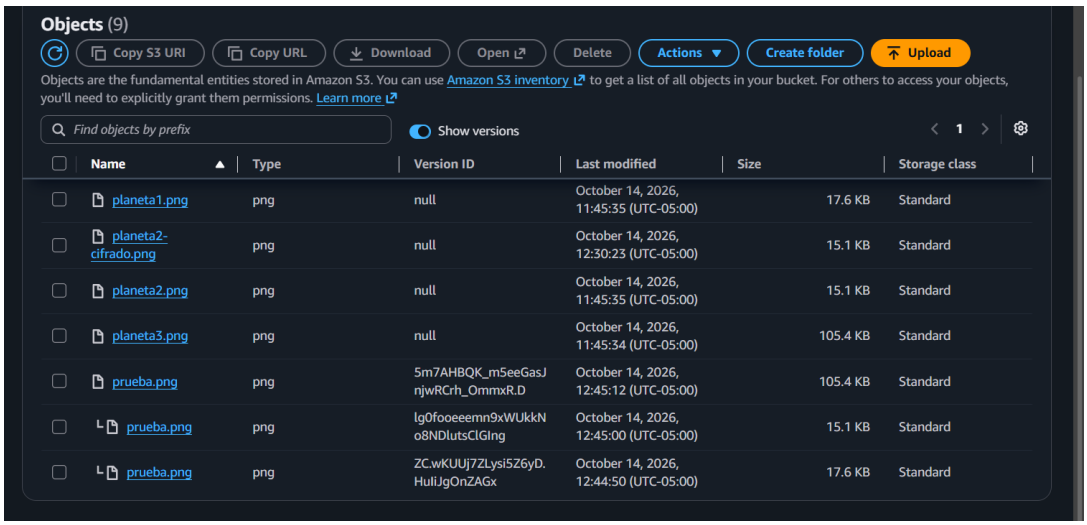
Regla de ciclo de vida indicada en la guía

Para originales/: versiones actuales a Standard-IA a los 30 días y Glacier Instant a los 90; versiones no actuales a Deep Archive a los 60 días, con eliminación a los 365 días y limpieza de delete markers expirados. Las capturas disponibles demuestran el versionado y la restauración; no se incluye una captura que confirme la activación de esta regla.

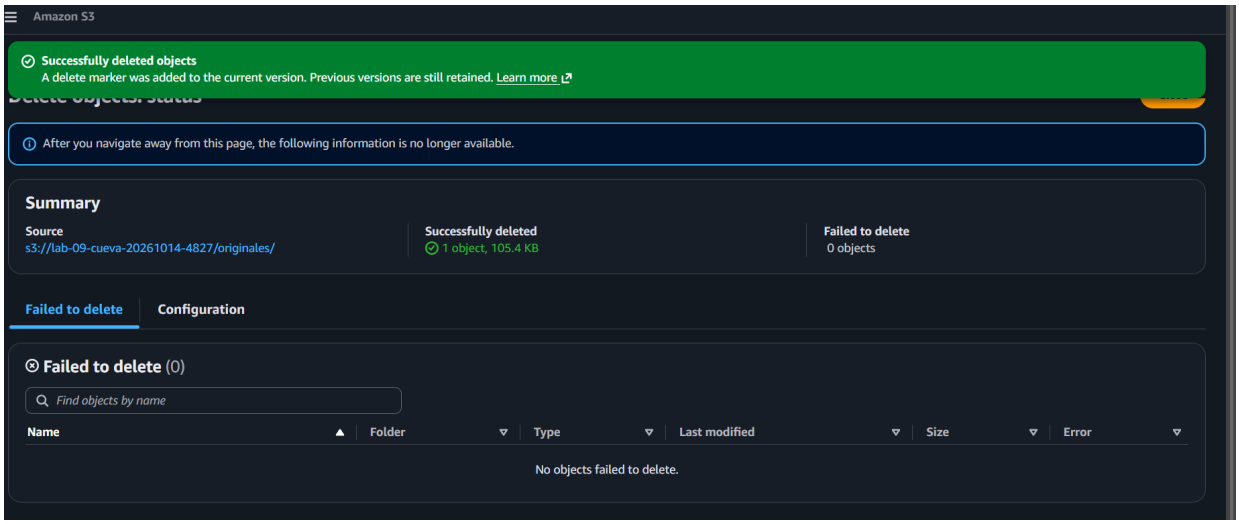
Reflexión de seguridad

El versionado permitió recuperar una imagen borrada. Las transiciones reducen costos de almacenamiento, pero las versiones antiguas también ocupan espacio; conviene revisar periódicamente la regla y las facturas.

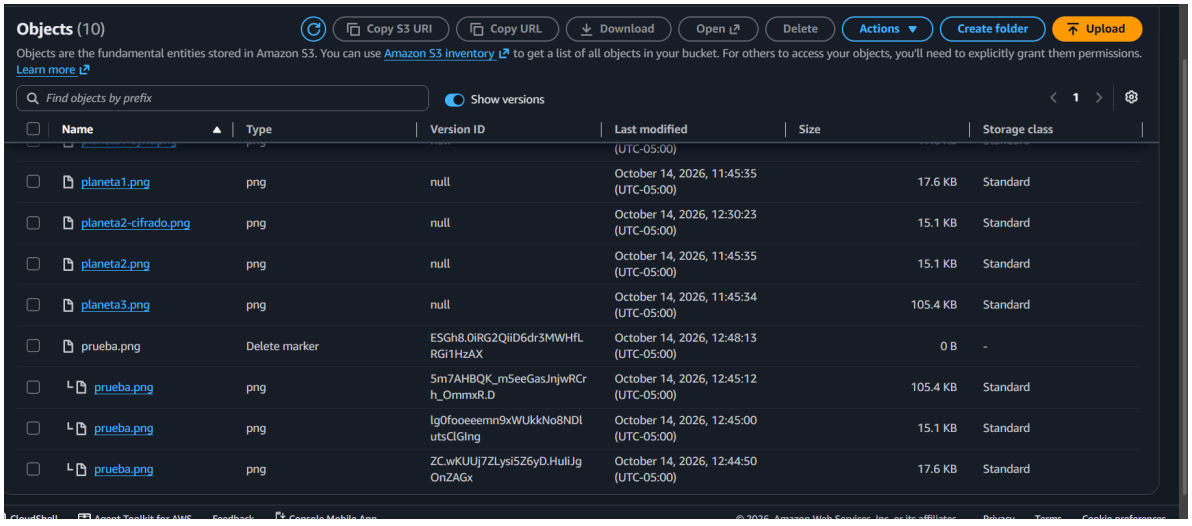
Evidencias del ejercicio 3



E3 · Tres versiones del mismo objeto en la consola.



E3 · Borrado lógico mediante delete marker.



E3 · Imagen recuperada tras retirar el marcador.

Ejercicio 4: aplicación web de imágenes

Arquitectura

El navegador pide a la API una URL de subida de 5 minutos, envía el archivo directamente al bucket S3 privado y confirma la carga. La API valida tipo, tamaño y bytes iniciales. Para mostrar la galería genera URL de lectura de 15 minutos. El frontend no contiene claves AWS.

1. ¿Por qué son más seguras las presigned URLs que un bucket público?

Conceden acceso limitado a una operación, un objeto y un plazo. El bucket sigue privado y el navegador no recibe credenciales AWS.

2. ¿Qué pasa si alguien intercepta una URL?

Puede usarla hasta su vencimiento. El riesgo disminuye con HTTPS, caducidad corta, permisos mínimos y nombres de objeto únicos.

3. ¿Cómo eliminar claves del .env al desplegar en EC2?

Asignar a la instancia un IAM Role de mínimo privilegio. El SDK obtiene credenciales temporales automáticamente; se eliminan las claves y AWS_PROFILE del entorno.

4. ¿Cómo frenar subidas masivas?

Limitar las solicitudes de generación de URL por usuario o IP y aplicar cuotas. Esta API admite 10 solicitudes por minuto e IP.

5. ¿Qué validaciones extra recomienda?

Comprobar magic bytes, intentar decodificar la imagen y pasar antivirus antes de publicarla. La práctica verifica tipo, tamaño y firma inicial después de subir.

Pruebas obligatorias documentadas

Prueba	Resultado
Imagen válida	PUT directo a S3; visible en galería
PDF	Bloqueado en el navegador
Archivo de 10 MB	Rechazo de la API: HTTP 400
URL de lectura	HTTP 200 al inicio; HTTP 403 tras 16 minutos
Credenciales en frontend	No se encontraron claves AWS
Subidas masivas	Solicitud 11 en un minuto: HTTP 429

Reflexión de seguridad

El bucket no se hizo público. Antes de exponer la API a Internet se necesita autenticación, autorización por usuario y análisis antimalware. La página actual funciona en localhost; S3 almacena las imágenes en la nube.

Entrega, fuentes y evidencias adicionales

Código fuente y video

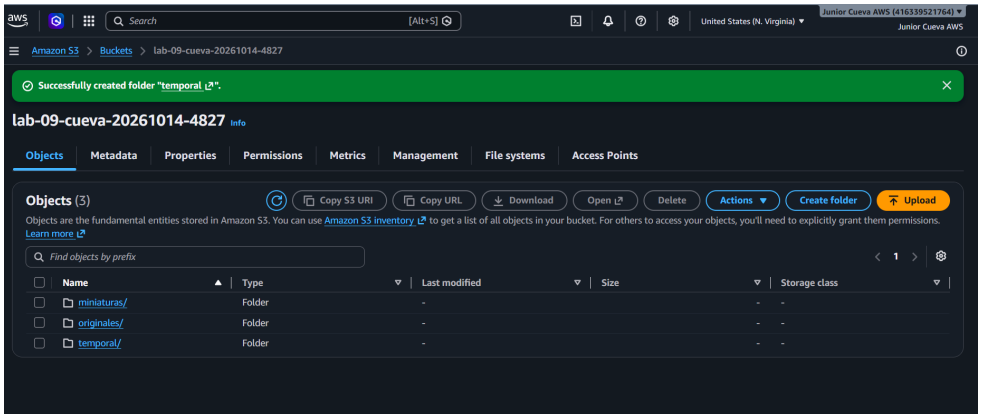
Repositorio: github.com/juniorcueva-star/SEMANA_9_NUBE_PAGINA_WEB
Video indicado en el documento: enlace de Google. No se verificó aquí la disponibilidad pública del video.

Referencias

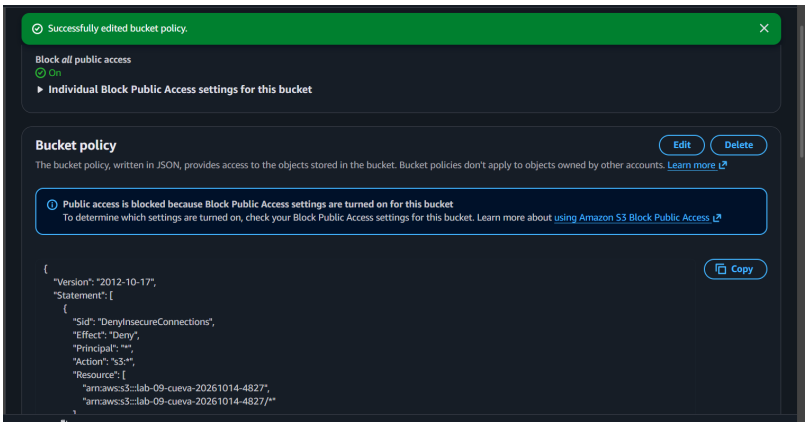
Amazon S3 User Guide: docs.aws.amazon.com/AmazonS3/latest/userguide/
Precios de S3: aws.amazon.com/s3/pricing/
Duraciones mínimas de Lifecycle: docs.aws.amazon.com/AmazonS3/latest/userguide/troubleshoot-lifecycle.html
Presigned URLs: docs.aws.amazon.com/AmazonS3/latest/userguide/using-presigned-url.html
IAM Roles para EC2: docs.aws.amazon.com/AWSEC2/latest/UserGuide/iam-roles-for-amazon-ec2.html
OWASP File Upload Cheat Sheet: cheatsheetseries.owasp.org.

Estado de las evidencias

Las capturas del documento original respaldan la creación del bucket, los objetos, el acceso denegado, IAM, el versionado, el marcador de borrado y la recuperación. La regla de ciclo de vida se describe según la guía, pero su activación no se acredita con estas capturas. La aplicación del ejercicio 4 y sus pruebas se documentan en el repositorio.



E1 · Estructura de carpetas lógicas del bucket.



E2 · Política de bucket que exige transporte HTTPS.